

TP : Audit de Conformité et Référentiels (ANSSI, CIS)

-

Objectifs

1. Déployer et utiliser un outil d'audit de conformité automatisé (Lynis) sur un système Linux.
2. Analyser les rapports générés pour identifier les écarts de conformité (Warnings).
3. Auditer la politique de sécurité locale d'un système Windows hors domaine.
4. Durcir les règles de mots de passe Windows pour s'aligner sur les recommandations de l'ANSSI.

Partie 1 : Cible Linux - Audit automatisé avec Lynis

Vous allez utiliser l'outil de référence Lynis pour calculer le score de durcissement (Hardening Index) de votre machine Linux fraîchement installée. Connectez-vous à votre machine Linux avec votre compte formation.

1.1 Déploiement et exécution du scan

1. Mettez à jour la liste des paquets et installez l'outil lynis en utilisant le gestionnaire de paquets de votre distribution.
2. Lancez une analyse de conformité complète du système. (L'analyse va défiler à l'écran et tester des centaines de points de contrôle. Laissez-la se terminer).

1.2 Analyse du rapport de conformité

Une fois le scan terminé, répondez aux questions suivantes en vous appuyant sur l'affichage final et sur les journaux de l'outil.

- **Questions à consigner :**
 - Quel est le score final obtenu ("Hardening index" sur 100) par votre machine ?
 - En utilisant la commande appropriée vue en cours, extrayez du fichier `/var/log/lynis.log` uniquement les lignes contenant des alertes (warning). Citez-en deux qui vous semblent critiques.

1.3 Vérification manuelle de la conformité (Focus ANSSI)

L'ANSSI impose l'utilisation d'algorithmes de hachage robustes (SHA-512 ou YESCRYPT) pour le stockage des mots de passe sous Linux.

1. Interrogez le fichier de configuration de création des comptes (`/etc/login.defs`) pour vérifier quelle méthode de chiffrement est actuellement configurée sur votre machine.

Partie 2 : Cible Windows - Audit et Durcissement

(Guide d'Hygiène ANSSI)

Sur un serveur Windows qui n'est pas rattaché à un domaine Active Directory, les règles de complexité et de renouvellement des mots de passe sont gérées par la Stratégie de Sécurité Locale. L'ANSSI impose des critères stricts pour contrer les attaques par force brute et le vol d'identifiants. Connectez-vous à votre machine Windows Server en tant qu'Administrateur.

2.1 État des lieux de la politique actuelle

1. Ouvrez une invite de commande (cmd) ou PowerShell.
2. Affichez la politique de mots de passe locale actuellement en vigueur sur le serveur.
- **Questions à consigner :**
 - Quelle est la longueur minimale actuellement exigée pour un mot de passe ?
 - Combien de mots de passe sont mémorisés dans l'historique par défaut (ce qui empêche l'utilisateur de remettre son ancien mot de passe) ?

2.2 Extraction et analyse du fichier de sécurité

Plutôt que d'utiliser l'interface graphique (secpol.msc), vous allez extraire la configuration brute pour l'analyser comme le ferait un outil d'audit automatisé.

1. Exportez la configuration de sécurité locale (/cfg) dans un fichier nommé secpol.inf à la racine de votre disque C:\.
2. À l'aide de PowerShell, lisez ce fichier et filtrez le résultat pour n'isoler que la ligne contenant la variable PasswordHistorySize.

2.3 Remédiation : Alignement sur le référentiel ANSSI

L'audit ayant révélé que la configuration par défaut n'est pas conforme, vous devez appliquer les recommandations de l'ANSSI. À l'aide de l'outil en ligne de commande approprié, appliquez **immédiatement** les trois paramètres suivants :

1. Interdire la réutilisation des **10** derniers mots de passe.
2. Imposer un changement de mot de passe au bout de **90** jours maximum.
3. Imposer une longueur minimale de **14** caractères.

Une fois les trois commandes exécutées, affichez de nouveau la politique locale pour valider que les compteurs ont bien été mis à jour avec vos nouvelles valeurs.

Critères du TP

- L'outil Lynis a été installé avec succès et le rapport final a pu être analysé.
- Les alertes critiques (Warnings) de l'environnement Linux ont été extraites.
- Le fichier secpol.inf a été généré avec succès sous Windows.
- La politique des mots de passe Windows a été modifiée en ligne de commande et respecte scrupuleusement les exigences de l'ANSSI.